

Políticas de Seguridad DLP

1. Introducción al Data Loss Prevention (DLP)

La Prevención de Pérdida de Datos (DLP) consiste en establecer políticas y controles que protejan la información confidencial de la empresa, evitando filtraciones, robos o fugas accidentales. El objetivo es asegurarse de que los datos sensibles sólo puedan ser accedidos o transferidos por las personas adecuadas y bajo condiciones controladas. El DLP es fundamental para cumplir la normativa, proteger la reputación de la empresa y evitar daños económicos.

2. Clasificación de datos

Para organizar y proteger mejor la información, TechCorp Inc. clasifica sus datos en tres categorías:

Datos Públicos: Información que puede ser compartida externamente sin restricciones (por ejemplo, comunicados oficiales, página web).

Datos Internos: Información para uso interno, cuyo acceso no debe salir de la organización (por ejemplo, manuales de procesos, agendas de trabajo).

Datos Sensibles: Información confidencial que, si se filtra, puede causar daños legales, económicos o de reputación (por ejemplo, datos personales de empleados o clientes, nóminas, código fuente, contratos).

Cada archivo o documento debe estar identificado según esta clasificación, y los responsables de cada departamento revisan periódicamente que la clasificación sea correcta.

3. Acceso y Control (Principio del Menor Privilegio)

El acceso a los datos en TechCorp Inc. se concede siguiendo el principio del menor privilegio: cada empleado sólo accede a lo que necesita para hacer su trabajo.

Revisión de permisos: Los responsables de área revisan los permisos de acceso cada trimestre y cada vez que hay cambios de puesto o bajas de empleados.

Solicitudes de acceso: Deben justificarse, y sólo se aprueban si es imprescindible para el desempeño del puesto. Toda solicitud se valida primero por el responsable y después por el área de TI.

Retirada de permisos: Los accesos se eliminan de inmediato cuando un empleado cambia de función o abandona la empresa.

4. Monitoreo y Auditoría

Para asegurar el cumplimiento de estas políticas, se monitorizan y auditan los accesos y movimientos de datos sensibles.

Se usan herramientas DLP y SIEM para registrar accesos, transferencias y manipulaciones de archivos sensibles.

Las alertas de actividades sospechosas son revisadas por el equipo de Seguridad de la Información.

Se realiza una auditoría de accesos y permisos cada tres meses.

5. Prevención de Filtraciones

Se exige el cifrado de los datos sensibles en portátiles, servidores y copias de seguridad.

Se restringe el uso de dispositivos externos (USB, discos duros) únicamente a personal autorizado. El envío de datos sensibles por correo electrónico debe realizarse cifrado y sólo a destinatarios internos o de confianza. Se prohíbe la subida de archivos sensibles a plataformas no autorizadas.

6. Educación y Concientización

Todos los empleados reciben formación anual sobre:

- Qué datos se consideran sensibles.
- Buenas prácticas de seguridad digital.
- Los riesgos de usar dispositivos de almacenamiento externos.
- Cómo actuar ante una sospecha de incidente de seguridad.

Además, se envían recordatorios periódicos y se realizan ejercicios de simulación de fuga de datos.

7. Ejemplo Práctico: Control de Dispositivos USB

Como parte de estas políticas, se implementa la restricción por defecto del uso de dispositivos USB. El acceso está bloqueado para todos los usuarios, excepto para quienes lo necesitan justificado y aprobado por TI y su responsable.